Politechnika Krakowska
im. Tadeusza Kościuszki

Wydział Informatyki i Matematyki

Wiktor Zmiendak

Numer albumu: 142706

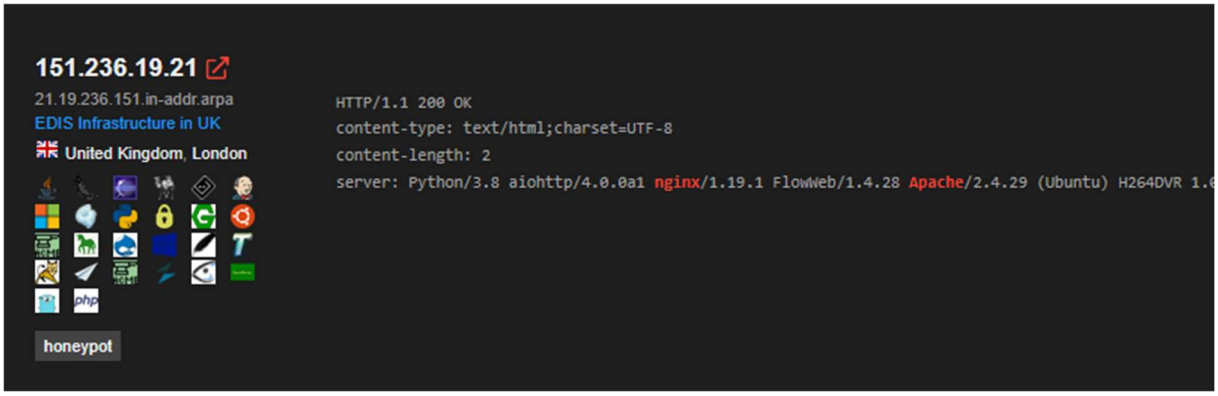
Sprawozdanie

Wykrywanie zagrożeń i reakcji na incydenty

Laboratorium nr 7

ZADANIE 1

W ramach pierwszego zadania należało przeanalizować wybrane urządzenie przy pomocy narzędzia Shodan. W typ przypadku wybrano usługę Widoczną na poniższym screenie (https://www.shodan.io/host/151.236.19.21):



Odczytane parametry:

- **Adres IP:** 151.236.19.21
- **Kraj i lokalizacja:** Wielka Brytania, Londyn
- **Otwarte porty:** 6622
- **Wykryte oprogramowanie:** Wiele (Honeypot) – serwer udaje że posiada różne usługi
- **Potencjalne ryzyko:** Potencjalnie znikome

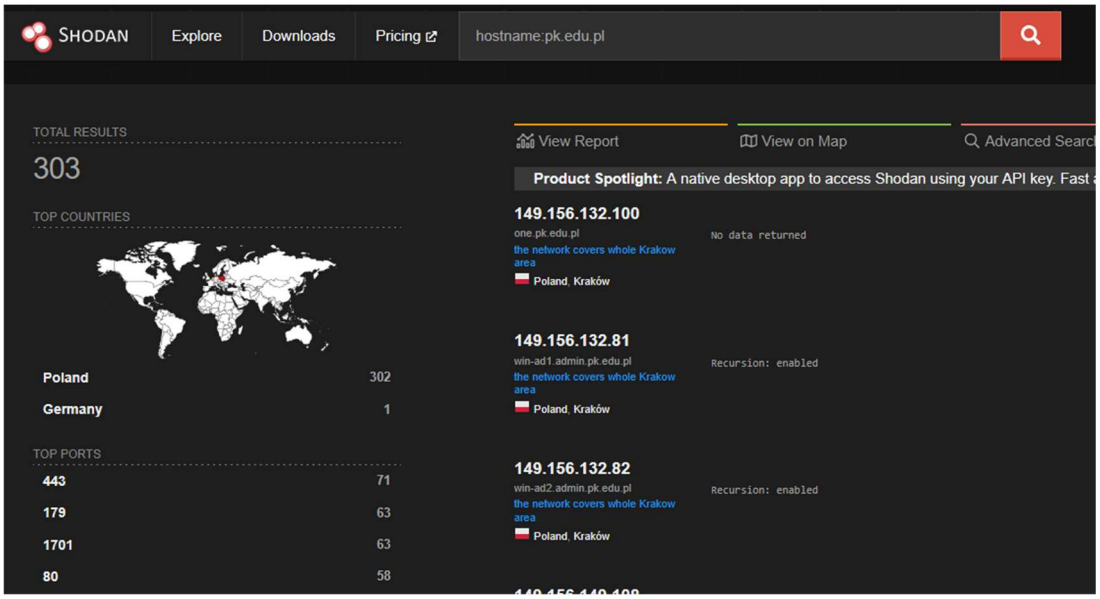
Z perspektywy zwykłego użytkownika usługa nie stanowi większego zagrożenia. Wystawiony serwer celowo udaje, że posiada dziesiątki różnych usług, w tym te znane z wielu podatności. Celem wystawienia takiej usługi jest często zwabienie automatycznych skanerów i hakerów, a następnie rejestrowanie w jaki sposób próbują oni wykorzystać luki w zabezpieczeniach.

Przedrostek HTTP oraz brak sekcji certyfikatu SSL/TLS wskazują na brak jakiegokolwiek szyfrowania co w przypadku honeypodu może być celowe i stanowić zachętę do przeprowadzania ataku.

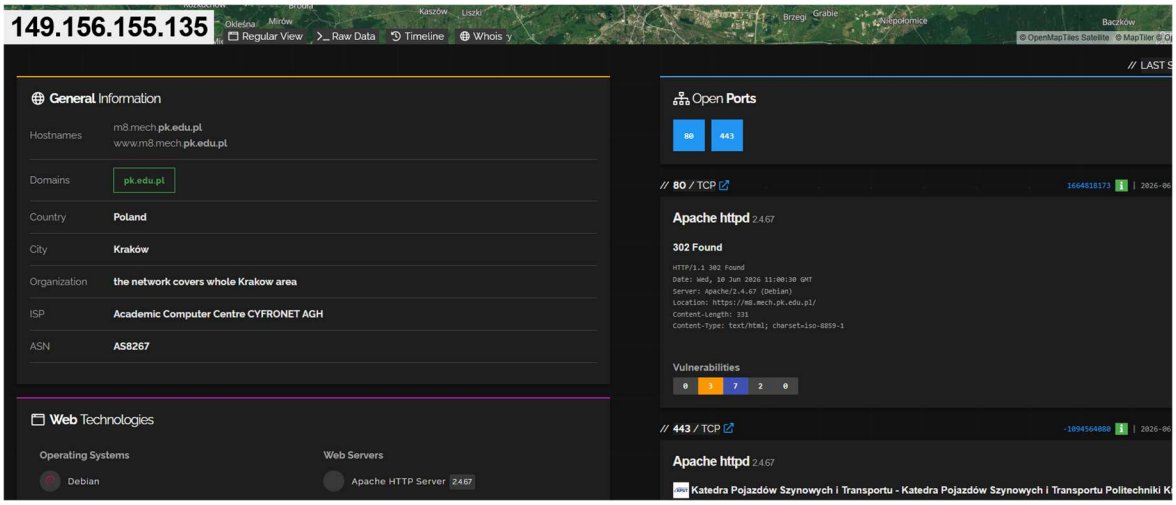
ZADANIE 2

Celem drugiego zadania było wybranie danej organizacji i przeprowadzenie krótkiej analizy. W tym przypadku wybrano Politechnikę Krakowską.

Shodan wskazuje nam 303 wystawione usługi powiązane z naszą uczelnią:



Ponieważ większość usług było bardzo podobnych wybrano przykładową należącą do wydziału mechanicznego.



Potencjalnie jednym z większych zagrożeń tutaj jest obecność przestarzałych modułów serwera Apache httpd 2.4.67. Jest to dosyć świeża wersja z 2026 natomiast podatności które możemy znaleźć w analizie Shodana pochodzą z lat 2007-2013. W momencie wykrycia przez niego obecności starych lub nieaktualizowanych modułów może uznać to za zagrożenie. Ryzyko w takim wypadku polega na tym, że administratorzy często aktualizują główny silnik serwera pozostawiając w systemie porzucone od lat dziurawe moduły rozszerzające jego funkcje.

Dla administratorów tego konkretnego serwera rekomendacją wydaje się więc przeprowadzenie audytu oraz sprawdzenie czy moduły takie jak mod_fcgid, stare wersje mod_authnz_external czy mod_perl są do czegokolwiek potrzebne. Jeśli nie to należałoby je wyłączyć.

W ramach przeprowadzanej analizy wybrano dwa błędy o wysokim wskaźniku ryzyka, które mogą przysporzyć negatywne skutki w środowisku uniwersyteckim:

- **CVE-2013-4365:** Jest to błąd przepełnienia bufora na stercie w komponencie odpowiedzialnym za komunikację z aplikacjami FastCGI. Błędy pamięci tego typu są jednymi z najgroźniejszych, ponieważ pozwalają atakującemu na wysłanie specjalnie spreparowanego żądania HTTP, które wychodzi poza przydzieloną pamięć serwera. Może prowadzić to do wykonania dowolnego kodu z poziomu uprawnień usługi Apache, potencjalnie przejmując kontrolę nad maszyną.
- **CVE-2011-2688:** Luka typu SQL Injection w skrypcie uwierzytelniającym opartym na Perlu. Atakujący może wstrzyknąć własne zapytania do bazy danych z poziomu pola "użytkownik" podczas próby logowania. Może to doprowadzić do całkowitego ominięcia mechanizmu logowania bez znajomości hasła, a w najgorszym scenariuszu wykradnięcia całej bazy danych kont studentów lub pracowników naukowych.